

Behavioral UEBA for the Age of AI-Enabled Threats

Why detect-and-respond no longer defends critical infrastructure

V-Intelligence | 22nd Century Technologies

Part 1: The Problem - why an advanced solution is needed

Valid-account attacks

AI-speed adversaries

Alert-fatigued SOC's

The SOC Runs on SIEM and UEBA Today

Collect, correlate, alert, triage, respond



- **The model assumes the attack produces a signal that crosses a rule or a threshold.**
- It assumes a known signature, or a deviation large enough to stand out from a baseline.
- And it assumes a human analyst has the time to triage what fires.

How Detection Works Today, and Where It Breaks

How it works

- Signature and correlation rules match known-bad patterns.
- UEBA adds statistical baselines (peer and self) and risk scores.
- Alerts are ranked by severity and pushed to the SOC queue.

Where it breaks

- **Magnitude, not meaning: 47 files is 47 files, intent is lost.**
- **Thresholds miss slow, valid-account, living-off-the-land attacks that never spike.**
- Per-source silos make one attacker look like ten users.
- Alert fatigue: analysts drown; real signal is buried in noise.
- Reactive: it detects after the fact, not before.

The SIEM / UEBA Landscape

Mature tools, the same structural limits

Tool	Category	What it does
Splunk Enterprise Security	SIEM	log search, correlation rules, dashboards
IBM QRadar	SIEM	flow + log correlation, offense scoring
Microsoft Sentinel	Cloud SIEM + SOAR	KQL analytics, automation, some UEBA
Exabeam / Securonix	UEBA-led	behavioral baselining, risk scoring
Elastic Security / Google SecOps	SIEM	search, detections, pipelines at scale
LogRhythm / Devo / Sumo Logic / Rapid7	SIEM	log analytics and detections

All are excellent at collecting and searching logs and at matching known patterns. All share the same limit: they alert on magnitude and signatures, not on the meaning and direction of behavior, so the valid-account, slow, AI-speed adversary walks past.

The Inflection: AI-Enabled (Mythos-Level) Attackers

Adversaries now wield AI that finds and exploits vulnerabilities at machine speed

- **Offensive AI (Mythos-level) autonomously discovers vulnerabilities, chains low-severity weaknesses, and exploits them, faster than humans can respond.**
- In 2025, an AI-orchestrated espionage campaign (Anthropic GTG-1002) ran largely autonomously against roughly 30 targets at machine speed.
- Threats now evolve faster than vulnerability disclosure and patch cycles; attackers exploit before a CVE or patch exists.
- **By the time a detect-and-respond pipeline fires, the breach is already complete.**
- **Detect-and-respond, the model every SIEM is built on, cannot defend U.S. infrastructure against this.**

Mythos-Level Attacks Mean Operational Disruption

Not data loss alone: mission and infrastructure impact

Energy / Water	Telecom	Transport / Logistics	Defense / Mission
pre-positioned access enables disruption of power, water, and fuel on demand	carrier-scale espionage and the ability to degrade communications	route, depot, and fulfillment disruption that stalls mobilization	loss of decision time and readiness when it is needed most

Adversaries pre-position quietly, on valid credentials, to disrupt critical infrastructure at the moment of their choosing. The cost of a missed warning is operational, not just informational.

Recent Attacks Current Tools Could Not Stop

Campaign	What it was	Why current tools missed it
Volt Typhoon (2023-24)	living-off-the-land pre-positioning in U.S. critical infrastructure, 5+ year dwell	valid accounts, no malware, no signature, sub-threshold
Salt Typhoon (2024-25)	telecom espionage at carrier scale	slow, valid-account, below every alert
SolarWinds (2020)	trojanized signed update pushed to ~18,000 organizations	trusted, signed update, no anomaly to flag
MOVEit (2023)	mass zero-day exploitation	no CVE or signature at time of exploit
XZ Utils (2024)	multi-year supply-chain backdoor in a core library	trusted dependency, no known-bad version
Colonial Pipeline (2021)	ransomware, fuel-supply disruption	credential access, detected too late to prevent impact

The common thread: valid credentials, no signature, no spike, or a trusted path. Magnitude-and-signature detection had nothing to fire on.

WHY WE NEED AN ADVANCED SOLUTION

- Current SIEM and UEBA detect magnitude and signatures; they miss meaning and direction.
- They cannot catch valid-account, living-off-the-land attacks that cross no threshold.
- They are reactive, and AI-speed adversaries are gone before detect-and-respond fires.
- And they overwhelm the SOC with alerts instead of giving analysts a ranked, explainable verdict.

We need behavior read as meaning, detection that is preemptive and precise, and a SOC that is helped, not buried.

PART 2

The Solution: A Behavioral Digital Twin

Read behavior as meaning, track where each entity is heading, hand the SOC a ranked, explainable verdict.

Input Data: the Logs the SOC Already Collects

No new sensors. The twin sits downstream of your existing SIEM.

Log source	Signal it carries
Identity / auth	who, when, from where, privilege use
File / data	access, volume, sensitivity, movement
Network / flow	destinations, beaconing, data egress
DNS	resolution patterns, DGA, rare domains
Endpoint / process	process lineage, living-off-the-land tools

Collection stages

- Ingest from the SIEM / forwarders
- Normalize and parse to a common schema
- Group events into behavioral dimensions
- Serialize and embed; store as vectors

Scale of the proof-of-concept: 250 entities, 485 days, about 14 million events across five log sources. Behavioral snapshots are stored as 1536-dimension vectors in a PostgreSQL pgvector database, so similarity and drift are queried directly in the database.

The Dimensions We Model, and Why

Five behavioral zones, 23 features; identity as context

Identity	role, department, clearance, user type	context
Access pattern	logins, sources, destinations, off-hours, methods (7 features)	action
Data behavior	file volume, sensitivity, breadth, writes (6 features)	action
Network footprint	egress bytes, destinations, DNS patterns (5 features)	action
Risk posture	endpoint and process risk scores (5 features)	action

Why these: an attacker on valid credentials betrays themselves not in one number but across zones at once. Identity sets the peer group; the four action zones carry the behavior we score against it.

Aggregation: from Activity to a Comparable Window

Windowed so behavior can be compared over time and across peers

Today (proof-of-concept)

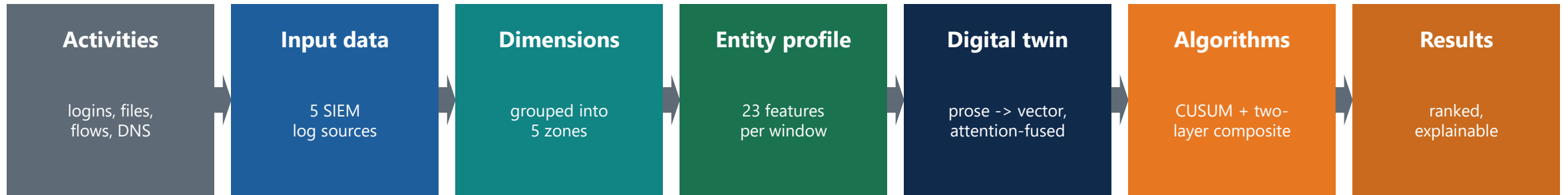
- Weekly aggregation across 485 days
- Long horizon proves slow-drift detection
- One trajectory point per entity per week

Design target

- **Hourly aggregation for near-real-time detection**
- Same pipeline, finer window: faster warning
- Shrinks dwell time from weeks toward hours

The method is window-agnostic. The current build aggregates weekly because the study spans 485 days and targets slow living-off-the-land drift; the same serialize-embed-compose-score pipeline runs at an hourly cadence to move detection closer to real time.

End-to-End Flow: Activity to Verdict

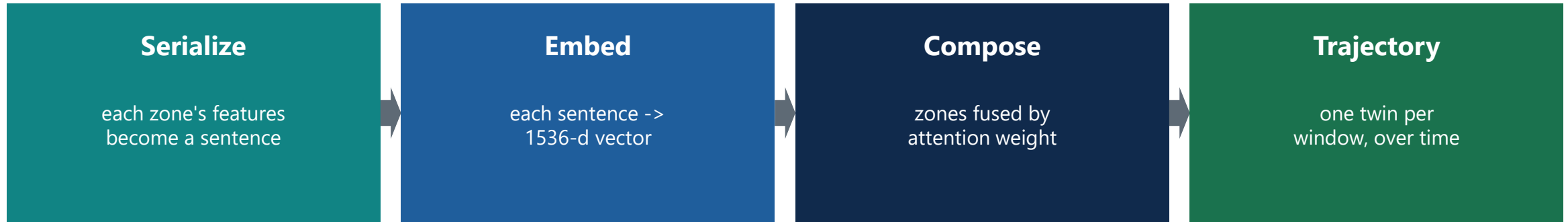


One unbroken path: the raw events the SOC already has become one ranked, explainable verdict, with the reason and the MITRE direction attached.

- No new collection: it consumes existing logs.
- No labels required: the twin is unsupervised.
- Every score is traceable back to the behavior that caused it.

How the Digital Twin Is Built

Raw metrics become meaning before they become math



- **Meaning over magnitude: "47 files" becomes "reaching far more sensitive data than peers, and widening."**
- Composition, not concatenation: zones are fused by attention weight, so the signal that matters dominates.
- Drift is direction in meaning-space: the cosine distance between successive twins, tracked over time.

The Algorithms: Two Complementary Layers

Precision first, discovery alongside

Layer A -- Precision (production)

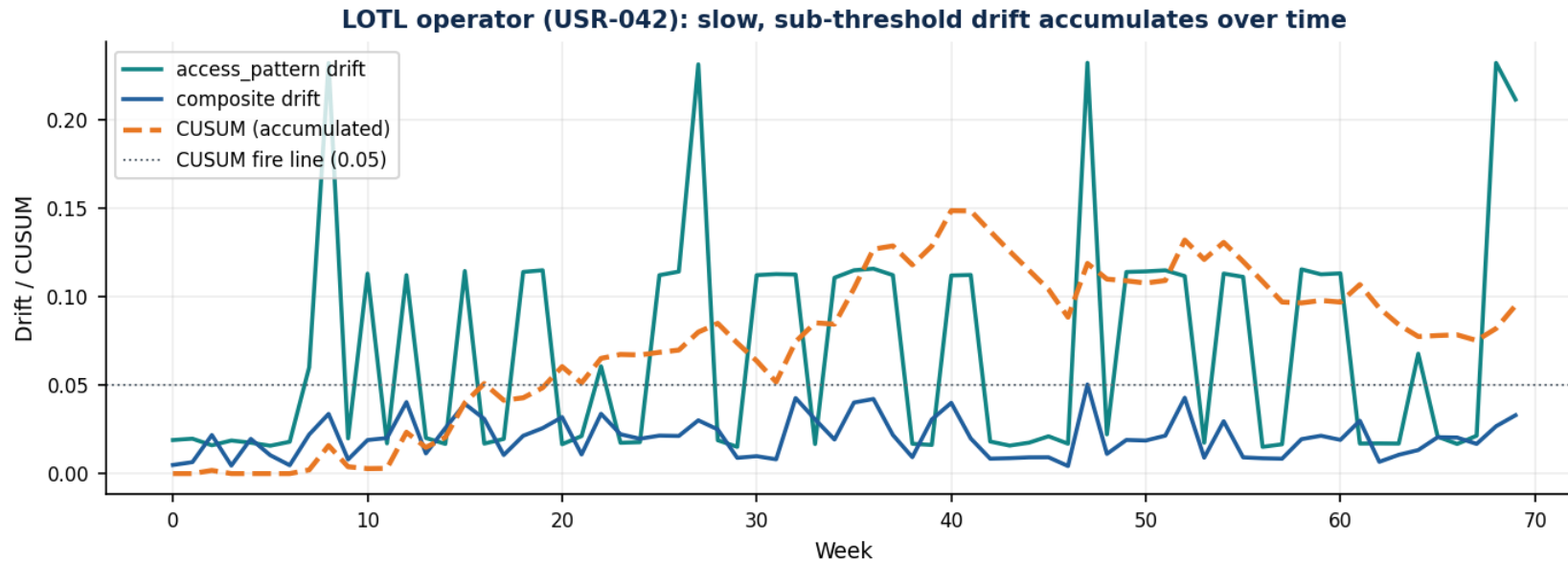
- **Multi-front threat-profile detector.**
- Matches entities to named known-bad fingerprints (mass collection, C2 beacon, DGA, recon fan-out, LOTL).
- Scored against role-group peers; fires only on a corroborated match.
- **Result: 4 of 4 attackers at 0 false positives.**

Layer B -- Discovery (the twin)

- **CUSUM accumulates slow drift that no single week would trip.**
- Direction projected onto MITRE ATT&CK concepts: names where the entity is heading.
- Composite score ranks every entity, no fingerprint needed.
- **Surfaces 4 of 4 by rank where classical methods catch 0 of 4.**

Slow Drift, Made Visible

Real trajectory: what CUSUM accumulates that a weekly threshold never trips



- Each week's drift is small, below any alert line.
- CUSUM sums the small, persistent pushes.
- It crosses the fire line and stays, so the slow operator is caught while still inside.

This is the signal classical point-anomaly methods miss: no single week is anomalous, but the direction is, sustained and accumulating.

Results: the Blind Test

Four nation-state-style attackers hidden among 250 entities

Method	Catches	Note
Precision detector (Layer A)	4 of 4 at 0 false positives	named fingerprint per attacker
Discovery twin (Layer B)	4 of 4 by rank (8.1% operating point)	no fingerprint; names MITRE direction
Isolation Forest / One-Class SVM / LOF	0 of 4	point-anomaly, no behavior over time
Z-score baseline	1 of 4	magnitude only

- Insider caught by mass collection + rare destinations; Slow APT by a 386-day C2 beacon + 160 DGA domains.
- Living-off-the-land operator caught by anomalous process use; telecom-pivot by reconnaissance fan-out.

Controlled, synthetic-data proof-of-concept (250 entities, 485 days). Indicative, not a guarantee of field performance.

What This Gives the SOC Analyst

Less noise, earlier warning, a verdict you can act on

Workload	Quick detection	Action
One ranked queue, not a flood. The analyst sees the few entities that matter, each already explained.	Slow, valid-account drift is caught while it builds, not after exfiltration. CUSUM warns weeks early.	Every alert carries its reason and a MITRE direction, so triage starts at "what and where," not "is this real?"

The shift: from chasing thousands of magnitude alerts to acting on a short, ranked, explainable list, so the analyst spends time on response, not triage.

THE BEHAVIORAL ANSWER

- Reads behavior as meaning, not magnitude, from the logs you already collect.
- Catches the valid-account, living-off-the-land attacker that crosses no threshold.
- Precision layer at 0 false positives; discovery twin that needs no prior fingerprint.
- Hands the analyst a ranked, explainable verdict with its MITRE direction attached.

From detect-and-respond, too late, to read-the-meaning and warn early.